

SIMATS ENGINEERING
CO4 ASSESSMENT TOOL 03

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1410

COURSE OUTCOME COVERED

***CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 05

Total Marks:100

Annexure A

CASE STUDY

Code of Conduct:

*I **SHAIK ASHA (192473025)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

1. TJX Companies Wireless Network Breach, 2005–2007

A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.

Introduction

The e-commerce application is exposed to several security risks because of suspicious HTTP requests, inadequate input validation, an outdated Apache server, and the absence of a Web Application Firewall (WAF). The observed activities indicate possible attempts at directory traversal, SQL injection, Cross-Site Scripting (XSS), and exploitation of known web-server vulnerabilities. A comprehensive penetration test using Kali Linux can identify these weaknesses and help establish a defense-in-depth security strategy.

Possible Attack Vectors

1. **Web Server Vulnerabilities:** The outdated Apache version may contain publicly known vulnerabilities that attackers can exploit to gain unauthorized access or execute malicious actions.
2. **Directory Traversal:** Attempts to access hidden directories may indicate directory traversal or information-disclosure attacks. Attackers may try to access configuration files, backups, logs, or other sensitive resources.
3. **Injection Attacks:** Malicious input submitted through login forms, search fields, payment forms, or other parameters may be used for SQL injection or command injection.
4. **Cross-Site Scripting (XSS):** If user input is displayed without proper validation and output encoding, attackers may inject scripts that execute in another user's browser.
5. **Outdated Software Components:** Vulnerable versions of Apache, PHP, frameworks, plugins, or libraries can provide attackers with known attack paths.

Reconnaissance Phase

The first phase is information gathering. The assessment should be performed only against systems for which permission has been obtained.

Kali Linux tools that can be used include:

- **Nmap:** Identifies open ports, services, and server versions.
- **WhatWeb:** Identifies technologies, frameworks, and web-server information.
- **Nikto:** Performs web-server security checks and identifies potentially dangerous files and outdated components.
- **Burp Suite:** Intercepts and analyzes HTTP requests and responses.

The objective is to understand the application's attack surface without making destructive changes.

Vulnerability Scanning

After reconnaissance, vulnerability scanning is performed to identify weaknesses.

Nmap can be used for service and version discovery:

```
nmap -sV <authorized-test-host>
```

Nikto can be used to identify common web-server misconfigurations:

```
nikto -h http://<authorized-test-host>
```

Burp Suite can be configured as a proxy to inspect requests generated by the application's login, registration, search, and transaction functions.

The findings should be verified manually because automated scanners can generate false positives.

Controlled Exploitation and Validation

The next step is to validate whether identified vulnerabilities are actually exploitable. Burp Suite can be used to modify parameters and observe how the application responds to unexpected input.

For example, testers can determine whether:

- Input is properly validated.
- Special characters are safely handled.
- Error messages expose internal information.
- Authentication controls can be bypassed.
- Sensitive files are accessible.
- User-controlled input is reflected into responses.

Any exploitation should be performed against a test account and controlled environment. Destructive actions, modification of real transactions, and extraction of real customer information should be avoided.

Layered Defense Strategy

1. Server Hardening

- Upgrade Apache and all software components to supported versions.
- Remove unnecessary services and modules.
- Disable directory listing.
- Apply secure file and directory permissions.
- Use HTTPS with strong TLS configuration.
- Remove default accounts and unnecessary files.
- Implement regular patch management.

2. Secure Coding

- Validate and sanitize all user inputs.
- Use parameterized SQL queries.
- Implement output encoding to prevent XSS.
- Avoid displaying detailed database or server errors to users.
- Use secure authentication and authorization mechanisms.
- Implement secure session management.

3. Web Application Firewall

A WAF should be deployed to detect and block common attacks such as SQL injection, XSS, malicious requests, and abnormal traffic patterns.

4. Network Protection

- Use firewalls and network segmentation.
- Restrict administrative services.
- Place the web server in a DMZ.
- Use IDS/IPS for monitoring suspicious traffic.
- Apply rate limiting and traffic filtering.

5. Monitoring and Incident Response

Server logs, WAF logs, authentication events, and network traffic should be continuously monitored. Alerts should be generated for repeated failed logins, suspicious requests, unusual transaction activity, and attempts to access restricted resources.

Conclusion

The incident is likely the result of multiple weaknesses rather than a single vulnerability. Combining server hardening, secure programming, patch management, WAF protection, network security, continuous monitoring, and incident-response procedures provides defense-in-depth and significantly reduces the probability and impact of future attacks.

2. Lowe's Wireless Network Intrusion, 2003

A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.

Introduction

The financial application contains SQL injection and Cross-Site Scripting vulnerabilities. In addition, detailed error messages expose database information and user input is not properly sanitized. These weaknesses can allow attackers to access confidential information, modify application behavior, or execute malicious scripts in victims' browsers.

SQL Injection

SQL injection occurs when an application directly combines untrusted user input with SQL statements. An attacker may manipulate parameters in login forms, search fields, or transaction-related requests so that the application's database interprets the input as part of the SQL command.

In this scenario, SQL injection could potentially allow an attacker to:

- Bypass authentication.
- Retrieve customer information.
- Access database metadata.
- Modify or delete records.
- Manipulate financial information.
- In severe cases, affect the availability of the application.

XSS

Cross-Site Scripting occurs when malicious user-controlled content is returned to a browser without appropriate output encoding.

An attacker may attempt to place malicious content in areas such as:

- User profiles.
- Comments.
- Search parameters.
- Transaction descriptions.
- Feedback forms.

If the application stores the malicious content and later displays it to other users, it represents **stored XSS**. If it is immediately reflected in a response, it may represent **reflected XSS**.

Possible consequences include session compromise, unauthorized actions performed through a victim's browser, phishing, and modification of displayed content.

Security Audit Methodology

Step 1: Reconnaissance

Identify application functionality, endpoints, parameters, authentication mechanisms, and technologies.

Tools such as **Nmap**, **WhatWeb**, and **Burp Suite** can assist in this phase.

Step 2: Intercept Requests with Burp Suite

Burp Suite can be configured as a proxy between the browser and test application. Requests generated by login, account-viewing, search, and transaction functions can then be inspected.

The tester identifies parameters that accept user-controlled data and observes how those parameters are processed.

Step 3: Test for SQL Injection

Potentially vulnerable parameters can be tested using controlled input variations in the authorized test environment.

SQLmap can assist in automated validation:

```
sqlmap -u "http://<authorized-test-host>/item?id=1" --batch
```

For POST-based applications, the tester can provide a captured request from Burp Suite to SQLmap.

The purpose is to determine whether the parameter is actually injectable and what level of database access is possible. Testing should not dump real customer information.

Step 4: Test for XSS

Using Burp Suite, the tester identifies locations where input is returned to the browser. Test payloads that do not cause damage can be used to determine whether the application correctly encodes user-controlled data.

The tester checks whether the application:

- Rejects unsafe input.
- Encodes HTML-sensitive characters.
- Applies appropriate Content Security Policy.
- Prevents script execution in inappropriate contexts.

Step 5: Analyze Error Messages

Detailed database errors should be intentionally triggered in the test environment to determine whether the application exposes:

- Database names.
- Table names.
- SQL statements.
- File paths.
- Framework information.
- Internal server details.

CIA Triad Impact

Security Property	Impact
Confidentiality	SQL injection may expose customer records, account information, and database contents. XSS may expose sensitive browser/session information.
Integrity	Attackers may modify database records or cause unauthorized actions through compromised sessions.
Availability	Malicious database queries or destructive operations could make services unavailable.

Mitigation Strategies

Input Validation

All input should be validated using allowlists where possible. Expected data types, lengths, ranges, and formats should be enforced.

Parameterized Queries

Applications should use prepared statements instead of constructing SQL queries through string concatenation.

Output Encoding

User-controlled content should be contextually encoded before being displayed in HTML, JavaScript, URLs, or other contexts.

Secure Error Handling

Users should receive generic error messages while detailed errors should be stored securely in server-side logs.

Secure Session Management

- Use secure, random session identifiers.
- Enable Secure and HttpOnly cookie attributes.
- Use appropriate SameSite settings.
- Expire sessions after inactivity.
- Regenerate session identifiers after authentication.
- Implement multi-factor authentication for sensitive operations.

Additional Security Controls

- Deploy a WAF.
- Implement Content Security Policy.
- Use HTTPS.
- Apply rate limiting.
- Perform regular vulnerability scanning.
- Conduct secure code reviews.
- Maintain dependency and patch management.
- Monitor authentication and transaction logs.

Conclusion

SQL injection and XSS can seriously compromise a financial application. Secure coding practices, parameterized queries, output encoding, secure session management, WAF protection, monitoring, and regular penetration testing should be implemented together to protect confidentiality, integrity, and availability.

3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the

attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

Introduction

An Evil Twin attack occurs when an attacker creates a rogue wireless access point that imitates a legitimate network by using the same or a similar SSID. Employees may unknowingly connect to the rogue access point, allowing the attacker to observe or manipulate network traffic and potentially capture credentials.

How the Attack Works

The attack generally follows these stages:

1. The attacker identifies the legitimate corporate SSID and observes wireless characteristics.
2. A rogue access point is configured to imitate the legitimate network.
3. The attacker attempts to make the rogue AP more attractive to nearby clients.
4. Employees accidentally connect to the malicious network.
5. The attacker can position the rogue AP between the victim and the legitimate network.
6. Unencrypted or improperly protected traffic may then be observed or manipulated.

Even when WPA2 encryption is used, simply knowing the network password does not guarantee protection against a rogue AP using the same SSID. Strong authentication and certificate validation are therefore important.

Using Aircrack-ng for Wireless Analysis

The Aircrack-ng suite can be used in an authorized laboratory to analyze wireless networks.

A tester can use wireless-monitoring capabilities to identify:

- SSIDs.
- BSSIDs.
- Channels.
- Signal strength.
- Authentication mechanisms.
- Duplicate or suspicious access points.

The purpose is to compare the legitimate AP with suspicious APs and identify differences such as unexpected BSSIDs, channels, or signal characteristics.

Using Wireshark

Wireshark can capture and analyze authorized network traffic.

It can help identify:

- Unexpected network connections.
- Authentication activity.
- Unusual DNS behavior.
- Suspicious HTTP traffic.
- Repeated connection attempts.
- Traffic originating from unexpected devices.

Encrypted traffic may not reveal its contents, but metadata and connection behavior can still provide useful evidence.

Weaknesses in WPA2-PSK Configuration

The existing configuration has several weaknesses:

- Shared password among employees.
- Possibility of weak or reused passwords.
- Lack of individual user authentication.
- Employees may not verify network authenticity.
- Lack of wireless intrusion detection.
- Insufficient monitoring for rogue access points.
- Lack of certificate-based authentication.

Countermeasures

1. Use WPA3-Enterprise or WPA2-Enterprise

Enterprise authentication provides individual credentials rather than one shared password.

2. 802.1X Authentication

Use 802.1X with a RADIUS server to authenticate individual users and devices.

3. Certificate Validation

Corporate devices should validate the authentication server's certificate to reduce the risk of connecting to a fraudulent network.

4. Wireless Intrusion Detection

Deploy WIDS/WIPS solutions to identify rogue access points and suspicious wireless behavior.

5. Network Segmentation

Separate employee devices, guest devices, IoT systems, and administrative systems using VLANs and firewall policies.

6. HTTPS and VPN

Sensitive applications should use HTTPS. A corporate VPN can provide an additional layer of protection when users connect through untrusted networks.

7. User Awareness

Employees should be trained to:

- Verify corporate network names.
- Avoid unexpected login prompts.
- Report suspicious Wi-Fi behavior.
- Avoid entering credentials into unknown portals.
- Contact IT when certificate warnings appear.

Conclusion

The Evil Twin attack demonstrates that a wireless network can be compromised through weaknesses in authentication and user awareness. Enterprise-grade authentication, certificate validation, wireless monitoring, network segmentation, encryption, and employee training provide stronger protection than a shared WPA2-PSK configuration.

4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.

Introduction

The organization has weaknesses at both the wireless and web-application layers. Weak Wi-Fi passwords allow an attacker to gain network access, while inadequate authentication and session management in the employee management system allow further exploitation. This creates an attack chain in which compromise of one layer facilitates attacks against another.

Phase 1: Wireless Reconnaissance

The tester first identifies authorized wireless networks and examines:

- SSIDs.
- Access points.
- Channels.
- Encryption mechanisms.
- Signal characteristics.
- Connected devices.

Kali Linux wireless-analysis tools such as **Aircrack-ng** can assist with authorized wireless reconnaissance.

The objective is to identify weak configurations without disrupting legitimate users.

Phase 2: Wireless Security Assessment

The tester evaluates the strength of the Wi-Fi authentication mechanism. A weak shared password may make unauthorized access easier.

The assessment should determine:

- Whether WPA2/WPA3 is used.
- Whether the password is sufficiently strong.
- Whether enterprise authentication is available.
- Whether guest and employee networks are separated.
- Whether network monitoring is implemented.

Phase 3: Network Reconnaissance

Once access has been legitimately obtained in the test environment, **Nmap** can identify authorized hosts and services.

For example:

```
nmap -sV <authorized-test-network>
```

This helps identify the employee management server and its exposed services.

Phase 4: Web Application Enumeration

Burp Suite can be used to inspect the application's HTTP requests and responses.

The tester examines:

- Login functionality.
- Session cookies.

- Access-control mechanisms.
- Employee profile functions.
- Administrative functions.
- API endpoints.
- Input parameters.

Phase 5: Vulnerability Identification

The application is assessed for common vulnerabilities such as:

- Broken authentication.
- Broken access control.
- Session fixation.
- Insecure session management.
- SQL injection.
- XSS.
- IDOR/broken object-level authorization.
- Security misconfiguration.

Automated tools such as **Nikto** can assist with basic web-server checks, while Burp Suite can provide detailed application-level analysis.

Phase 6: Controlled Exploitation

Confirmed vulnerabilities are validated using non-destructive test accounts.

For example, the tester can determine whether a normal employee account can access an administrative function. If access is incorrectly granted, this demonstrates a privilege-escalation or broken-access-control vulnerability.

No real employee information should be copied or modified during testing.

Phase 7: Privilege Escalation Assessment

The tester determines whether a low-privileged account can access resources belonging to higher-privileged users.

Tests include:

- Changing user identifiers in authorized requests.
- Accessing administrative URLs with a normal account.
- Checking server-side authorization.
- Testing whether role information is trusted from the client.
- Checking whether session privileges change correctly after login/logout.

Attack Chain

The overall attack chain can be represented as:

Weak Wi-Fi Password → Unauthorized Network Access → Network Reconnaissance → Web Server Discovery → Web Application Enumeration → Authentication/Session Exploitation → Authorization Bypass → Privilege Escalation → Confidential Data Exposure

Defense-in-Depth Framework

Wireless Layer

- Use WPA3-Enterprise or WPA2-Enterprise.
- Implement 802.1X authentication.
- Use strong individual credentials.
- Separate guest and employee networks.
- Deploy wireless intrusion detection.
- Monitor rogue access points.

Network Layer

- Use VLAN segmentation.
- Implement firewalls.
- Restrict lateral movement.
- Apply least-privilege network access.
- Monitor network traffic.
- Use IDS/IPS.

Application Layer

- Implement strong authentication.
- Use MFA for privileged users.
- Apply server-side authorization checks.
- Use secure session management.
- Regenerate session identifiers after authentication.
- Configure Secure, HttpOnly, and appropriate SameSite cookies.
- Validate all input.
- Use parameterized SQL queries.
- Apply output encoding.

Data Layer

- Encrypt sensitive data.
- Use least-privilege database accounts.
- Protect backups.
- Monitor database access.
- Maintain audit logs.

Monitoring Layer

- Centralize logs.
- Monitor authentication failures.
- Detect unusual account behavior.
- Alert on privilege changes.
- Conduct regular vulnerability assessments.

Conclusion

The incident demonstrates why wireless and web security cannot be treated independently. Defense-in-depth should be implemented across wireless, network, application, data, and monitoring layers. Even if an attacker compromises the wireless network, segmentation and strong application authentication should prevent further access to confidential employee information.

5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

5. Deauthentication Attack on a University Wi-Fi Network

Introduction

A deauthentication attack is a wireless denial-of-service technique in which an attacker causes clients to disconnect from an access point. Traditional Wi-Fi management frames were not always protected against forgery, allowing attackers to transmit forged deauthentication frames that appear to originate from a legitimate access point.

How the Attack Works

The general process is:

1. The attacker identifies a target access point and associated wireless clients.
2. The attacker monitors wireless traffic.
3. Forged deauthentication frames are transmitted.
4. Clients interpret the frames as legitimate disconnect requests.
5. Clients disconnect from the access point.
6. Automated repetition causes continuous disruption.

The attack primarily affects **availability** rather than directly providing access to confidential data.

Why the Attack Is Possible

Traditional wireless management frames can be vulnerable to spoofing when management-frame protection is not enabled.

An attacker may therefore impersonate an access point or client when transmitting certain management frames.

Kali Linux Analysis

In a controlled university security laboratory, Kali Linux can be used to analyze the attack.

Aircrack-ng can be used to monitor wireless networks and identify:

- Access points.
- Clients.
- Channels.
- Wireless management traffic.
- Abnormal disconnection activity.

A controlled test environment can then be used to reproduce the behavior without affecting production users.

Wireshark can analyze captured wireless traffic and help identify repeated deauthentication frames.

The security team can look for:

- Unusually high numbers of deauthentication frames.
- Repeated disconnect events.
- Unexpected source addresses.
- Abnormal wireless management traffic.

Impact on Availability

The attack can cause:

- Frequent user disconnections.
- Interrupted online classes.
- Failed file transfers.
- Disrupted video conferences.
- Interrupted cloud applications.
- Reduced employee/student productivity.
- Increased support requests.

If the attack continues for a long period, it can significantly reduce the availability of campus network services.

Mitigation Strategies

1. Enable Protected Management Frames

Use **802.11w / Protected Management Frames (PMF)** where supported. WPA3 requires stronger management-frame protection capabilities.

2. Use WPA3

WPA3 provides improved wireless security compared with older configurations and should be preferred where compatible.

3. Wireless IDS/IPS

Deploy a Wireless Intrusion Detection/Prevention System to detect abnormal deauthentication activity and rogue wireless devices.

4. Continuous Monitoring

Monitor:

- Deauthentication rates.
- Authentication failures.
- Rogue APs.
- Unexpected wireless devices.
- Channel interference.
- Repeated client disconnections.

5. Access Point Configuration

Use enterprise-managed access points with current firmware and security features. Disable unnecessary legacy protocols where practical.

6. Network Segmentation

Separate student, staff, guest, and administrative networks. Segmentation limits the effect of incidents on critical systems.

7. Incident Response

When abnormal deauthentication activity is detected:

1. Identify the affected access points.
2. Confirm whether the traffic is legitimate.
3. Identify the suspected rogue source.
4. Preserve wireless and network logs.
5. Coordinate with the wireless/network security team.
6. Apply containment measures.
7. Monitor the network after remediation.

Conclusion

Deauthentication attacks exploit weaknesses in wireless management-frame protection and can create significant denial-of-service conditions. Enabling Protected Management Frames, adopting WPA3, deploying wireless IDS/IPS, continuously monitoring wireless activity, maintaining updated access points, and implementing a strong incident-response process can substantially improve campus Wi-Fi availability and security.